

IF330 Pemrograman Web.

07 - PHP Security

Fenina Adline Twince Tobing

I Putu Ananta Yogiswara

PROGRAM STUDI INFORMATIKA
FAKULTAS TEKNIK DAN INFORMATIKA
UNIVERSITAS MULTIMEDIA NUSANTARA
SEMESTER GANJIL TAHUN AJARAN 2022/2023

REVIEW



- Database Introduction
- Database Design
- Database Connection
- Database Manipulation
- Multiple Tables Manipulation

TODAY's OUTLINE



- PHP Exception
- Password Hash & Verify
- Random Bytes & bin2hex for Token Generation
- Authentication System

PHP Exception

Exception handling is used to change the normal flow of the code execution if a specified error (exceptional) condition occurs. This condition is called an exception

```
<?php
//create function with an exception
function checkNum($number) {
    if($number>1) {
        throw new Exception("Value must be 1 or below");
    }
    return true;
}

//trigger exception
checkNum(2);
```

Try, throw & catch

- try - A function using an exception should be in a "try" block. If the exception does not trigger, the code will continue as normal. However if the exception triggers, an exception is "thrown"
- throw - This is how you trigger an exception. Each "throw" must have at least one "catch"
- catch - A "catch" block retrieves an exception and creates an object containing the exception information

Try, throw & catch

```
<?php
//create function with an exception
function checkNum($number) {
    if($number>1) {
        throw new Exception("Value must be 1 or below");
    }
    return true;
}

//trigger exception in a "try" block
try {
    checkNum(2);
    //If the exception is thrown, this text will not be shown
    echo 'If you see this, the number is 1 or below';
}

//catch exception
catch(Exception $e) {
    echo 'Message: ' . $e->getMessage();
}
```

Custom Exception

```
<?php
class customException extends Exception {
    public function errorMessage() {
        //error message
        $errorMsg = 'Error on line '.$this->getLine().' in '.$this->getFile().' : <b>'.$this->getMessage().'</b> is not a valid E-Mail address';
        return $errorMsg;
    }
}

$email = "someone@example...com";

try {
    //check if
    if(filter_var($email, FILTER_VALIDATE_EMAIL) === FALSE) {
        //throw exception if email is not valid
        throw new customException($email);
    }
}

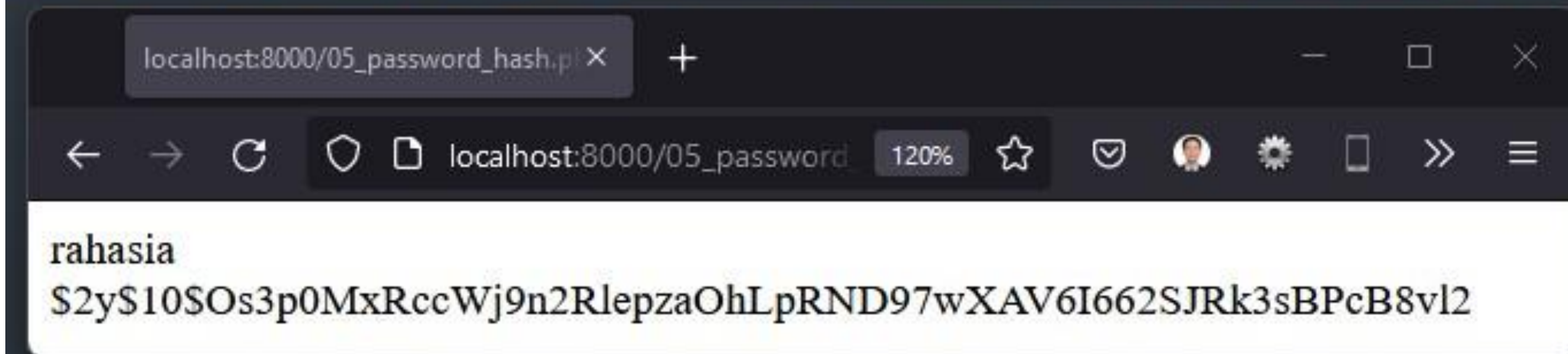
catch (customException $e) {
    //display custom message
    echo $e->errorMessage();
}
```

Password Hash

The password_hash() function can create a password hash.

password_hash(PASSWORD, ALGO, OPTIONS)

```
<?php  
echo "rahasia";  
echo "<br />";  
echo password_hash("rahasia", PASSWORD_BCRYPT);
```



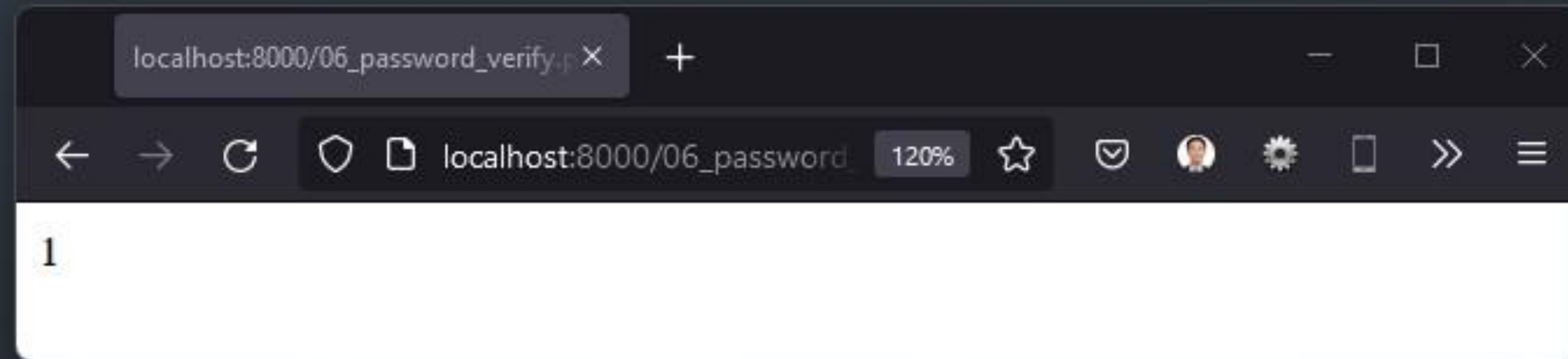
Password Verify

The password_verify() function can verify that a password matches a hash.

password_verify(PASSWORD, HASH)

```
<?php
$input = "rahasia";
$hassedPwd = password_hash($input, PASSWORD_BCRYPT);

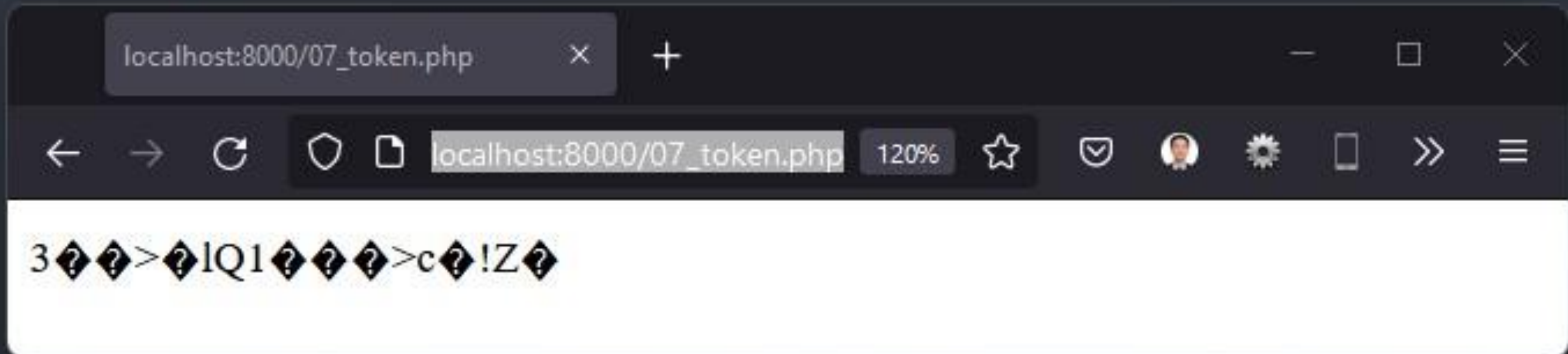
echo password_verify($input, $hassedPwd);
```



Random Bytes

random_bytes – Generates cryptographically secure pseudo-random bytes
`random_bytes(int $length): string`

```
<?php  
$token = random_bytes(20);  
echo $token;
```



bin2hex

bin2hex – Convert binary data into hexadecimal representation

`bin2hex(string $string): string`

```
<?php
$token = bin2hex(random_bytes(20));
echo $token;
```



Authentication System (Database)

Server: 127.0.0.1 » Database: umn_genap2122_pemweb_w7 » Table: users2

Browse Structure SQL Search Insert Export Import Privileges

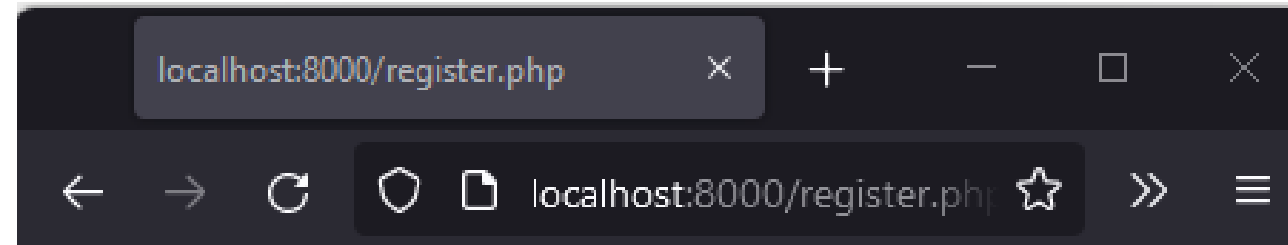
Table structure Relation view

#	Name	Type	Collation	Attributes	Null	Default	Comments	Extra
☐ 1	id 	int(11)			No	None		AUTO_INCREMENT
☐ 2	username 	varchar(25)	utf8mb4_general_ci		No	None		
☐ 3	password	varchar(100)	utf8mb4_general_ci		No	None		
☐ 4	role	varchar(10)	utf8mb4_general_ci		No	None		

```
<?php
// db.php
// DB Credentials
define('DSN', 'mysql:host=localhost;dbname=umn_genap2122_pemweb_w7');
define('DBUSER', 'root');
define('DBPASS', '');

// 1. Connect to DB
$db = new PDO(DSN, DBUSER, DBPASS);
```

User Registration



Register

-- Role -- ▼ Register

```
<h1>Register</h1>
<form action="register_process.php" method="post">
  <input type="text" name="username" placeholder="Username" /><!-- 3 Execute Query
  <input type="password" name="password" placeholder="Password"
  <select name="role" required>
    <option value="">-- Role --</option>
    <option value="student">Student</option>
    <option value="lecturer">Lecturer</option>
  </select>
  <button type="submit">Register</button>
</form>
```

```
<?php
require_once('db.php');

// Data from Form
$username = $_POST['username'];
$password = $_POST['password'];
$role = $_POST['role'];

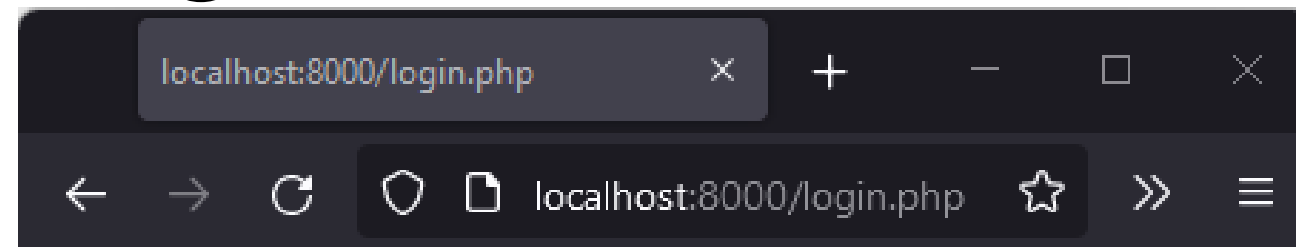
// Encrypt the Password
$en_pass = password_hash($password, PASSWORD_BCRYPT);

// 2. SQL Query
$sql = "INSERT INTO users2 (username, password, role)
        VALUES(?, ?, ?)";

// 3 Execute Query
$result = $db->prepare($sql);
$result->execute([$username, $en_pass, $role]);

header('location: login.php');
```

User Login



Login

Username

Password

Login

```
<h1>Login</h1>
<form action="login_process.php" method="post">
  <input type="text" name="username" placeholder="Username" />
  <input type="password" name="password" placeholder="Password" />
  <button type="submit">Login</button>
</form>
```

```
<?php
session_start();
require_once('db.php');

// Data from Form
$username = $_POST['username'];
$password = $_POST['password'];

// Check if user exists
$sql = "SELECT * FROM users2
        WHERE username = ?";
$stmt = $db->prepare($sql);
$stmt->execute([$username]);
$row = $stmt->fetch(PDO::FETCH_ASSOC);

if(!$row){
    echo "User not found";
}else{
    // Check if password correct
    if(!password_verify($password, $row['password'])){
        echo "Wrong password";
    }else{
        // Login success, set SESSION DATA
        $_SESSION['user_id'] = $row['id'];
        $_SESSION['user_role'] = $row['role'];
        $_SESSION['username'] = $row['username'];
        header('location: internal.php');
    }
}
```

Internal Page

```
<?php
session_start();
require_once('db.php');

if(!isset($_SESSION['username']) &&
    !isset($_SESSION['user_id']) &&
    !isset($_SESSION['user_role'])){
    echo "You don't have access to this page";
}else{
    if($_SESSION['user_role'] == "lecturer"){
        echo "THIS IS A LECTURER AREA<br />";
        echo "WELCOME " . $_SESSION['username'];
    }elseif($_SESSION['user_role'] == "student"){
        echo "THIS IS A STUDENT AREA<br />";
        echo "WELCOME " . $_SESSION['username'];
    }
}
```

SUMMARY

After finishing this module, you should be able:

- to understand how to implement PHP Exception
- to understand how to implement Password Hash and Verify
- to understand how to implement Random Bytes and bin2hex for Token Generation
- to understand how to implement Authentication System

NEXT WEEK'S OUTLINE

- PHP Security
- String Encryption
- User Authentication



next week

REFERENCES

- <https://www.w3schools.com/PHP/default.asp>
- <https://www.php.net/docs.php>
- Luke Welling & Laura Thomson. 2017. PHP and MySQL Web Development (5th ed)
- Robin Nixon. 2021. Learning PHp, MySQL & JavaScript.

Visi

Menjadi Program Studi Strata Satu Informatika **unggulan** yang menghasilkan lulusan **berwawasan internasional** yang **kompeten** di bidang Ilmu Komputer (*Computer Science*), **berjiwa wirausaha** dan **berbudi pekerti luhur**.



Misi

1. Menyelenggarakan pembelajaran dengan teknologi dan kurikulum terbaik serta didukung tenaga pengajar profesional.
2. Melaksanakan kegiatan penelitian di bidang Informatika untuk memajukan ilmu dan teknologi Informatika.
3. Melaksanakan kegiatan pengabdian kepada masyarakat berbasis ilmu dan teknologi Informatika dalam rangka mengamalkan ilmu dan teknologi Informatika.